PLAYBOOK DE RESPUESTA

PB-06 | Phishing reportado

Procedimiento estandarizado de triage y contención para PagoClaro C05

Caso C05: PagoClaro Fintech S.A.S.

Implementación de un SOC Nivel 1 | Ética del Hacking / Ciberseguridad Defensiva

Control documental	Versión 1.0 | 21 de octubre de 2026 Responsable documental: Analista SOC N1 del laboratorio. Alcance: procedimientos defensivos en activos autorizados; sin operaciones sobre terceros.
Activo / ámbito	8 estaciones Windows de operaciones, 3 portátiles Windows de gerencia, 5 macOS de desarrollo, 4 Ubuntu Server (bastión, réplica BD, API y respaldos). La prioridad final depende del activo afectado.

01. Objetivo

Detectar intentos de robo de credenciales de VPN, consola de pagos y correo de PagoClaro.

02. Disparador, fuente y umbral

Reporte del usuario o correo corporativo, análisis de cabeceras y eventos Kaspersky si hay descarga. Umbral: enlace/adjunto sospechoso con al menos un destinatario.

03. Severidad inicial y promoción

Baja si no hubo interacción; Media si clic/descarga; Alta si ingresó credenciales; Crítica si fue cuenta privilegiada comprometida.

04. Triage: validación paso a paso

1. Recopilar mensaje en formato .eml mediante proceso autorizado.
2. Verificar suplantación de proveedor de pagos, dominio, SPF/DKIM/DMARC y enlace sin abrirlo.
3. Preguntar si se ingresaron credenciales, se ejecutó archivo o se autorizó MFA.
4. Correlacionar con acceso VPN y alertas de protección web.
5. Comprobar cuántos destinatarios recibieron campaña sin difundir el contenido.

05. Contención autorizada a N1

- Instruir no interacción; pedir contención de dominio/URL a administrador.
- Solicitar cambio de contraseña y revocación de sesiones si hubo ingreso de credenciales.

06. Acciones no autorizadas a N1

- No abrir enlaces sospechosos en equipo de producción.
- No enviar .eml completo a verificadores públicos con datos personales.

07. Evidencia mínima preservada

- Cabeceras, remitente, hash/URL saneada, destinatarios y hora.
- Acciones del usuario confirmadas y alertas de protección web.

08. Escalamiento obligatorio a N2

Credenciales expuestas, ejecutable abierto, campaña masiva o suplantación de gerencia.

09. Criterios de cierre técnico

Se confirmó ausencia de interacción, se informó al usuario y se aplicó bloqueo preventivo autorizado.

10. Mejora continua

Refuerzo de verificación del proveedor y entrenamiento de personal de pagos.

11. Registro y trazabilidad

Bitácora del SOC: referencia INC-C05-AAAA-NNN, hora de la alerta (America/Bogota), activo, sensor, rule.id, analista, clasificación, evidencia inmutable, decisiones, autorización y hora de entrega/cierre. No incluir datos financieros sensibles.

12. Responsable, control de versión y fuente

Responsable: analista SOC N1 | Aprobación: responsable SOC | Versión: 1.0 | Revisión: 21/10/2026 | Fuente base: Parcial_SOC_N1_Etica_Hacking, PB-06 (Fase 6) y Anexo F. Los umbrales numéricos de esta adaptación son propuestas operativas, no detecciones que se haya comprobado activar.